PENETRATION TEST

REPORT

https://outreachdesk.cloud + api.outreachdesk.cloud - Security Assessment Full black-box, proof-only exploitation, ROE bounded

CLIENT	outreachdesk.cloud (owner-authorized)
TARGET	https://outreachdesk.cloud + api.outreachdesk.cloud
DATE	2026-08-13
MODE	Full black-box, proof-only exploitation, ROE bounded

Contents

Executive Summary 5
Findings 7
Negative testing performed (all classes, discriminating controls) 13
API Surface Map 16
Topology 16
Confirmed public endpoints (unauthenticated, non-401) 16
Reachable but parameter-gated / broken 16
Client-side routes (extracted from the JS bundle) 16
Security metadata mismatch (spec vs runtime) 16
Positive controls verified 17
Methodology and Scope 18
Engagement type 18
Engagement flow 18
Constraints and limitations 18
Hygiene 18
Addendum: Raw Evidence 19
Independent re-verification (2026-08-13, direct curl from assessment host) 19
Agent observations (customer run, 10 tasks completed) 19
Run statistics 19
Artifacts 20

Document Control

Client	outreachdesk.cloud (owner-authorized)
Report ID	ODC-2026-0813-C1
Version	v1.3
Date of engagement	2026-08-13
Classification	Confidential - authorized client engagement
Prepared by	Automated Security Assessment Pipeline
Distribution	Client only

Assessment Scope

In scope	https://outreachdesk.cloud, https://api.outreachdesk.cloud, https://auth.outreachdesk.cloud (web/API, ports 80/443)
Out of scope	Origin servers behind Cloudflare, authenticated operations (no credentials), infrastructure outside the three hosts
Authorization	Signed scope (owner-authorized scope)
Method	Recon -> crawl -> scanners -> autonomous agent -> independent re-verification -> zero-context judge
Engagement rules	Full testing per ROE, bounded requests, stop on WAF challenge

Rules of Engagement

- Scope: Web/API of the three hosts only; no pivoting, no other hosts
- Allowed: Full OWASP testing incl. SQLi/XSS/SSRF/auth-bypass; proof-only exploitation; bounded brute-force
- Forbidden: Data modification, DoS/load testing, data dumps, destructive SQL, persistence
- Stop conditions: WAF challenge, client request, out-of-scope contact

Assumptions and Requirements

- Scope confirmed and authorized before testing begins
- Client designates an authorized contact for queries
- Report delivered 5-10 business days after testing ends
- Critical findings communicated upon discovery

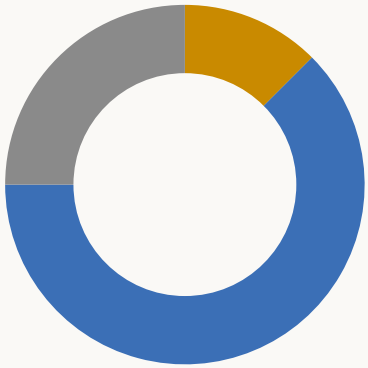
- Any scope change goes through a written change process
- Authenticated surface excluded (no credentials supplied)

This report contains no fabricated evidence. Every finding carries a reproduction path that was independently re-executed.

Executive Summary

0	0	1	5	2	8
Critical	High	Medium	Low	Info	Total

SEVERITY DISTRIBUTION



Medium - 1 (exposure)
Low - 5
Info - 2
Critical - 0

ENGAGEMENT FACTS

- 19 client-side routes mapped from the SPA bundle, 77 API exchanges captured
- 247 API paths / 302 operations documented in the exposed OpenAPI schema
- Full black-box run: 10 agent tasks, 80+ tool calls, every injection class tested
- SQLi (boolean + UNION) on 4 surfaces, cmdi, SSTI, SSRF, IDOR, auth bypass - all negative
- 8 findings (1 medium, 5 low, 2 info), all verified by independent re-execution

ASSESSMENT MODE

Full black-box, unauthenticated, proof-only exploitation under ROE. No WAF bypass attempted. No data modification, no dumps, no DoS - per rules of engagement.

B+ **Overall posture: good.** No high or critical findings and no exploitable vulnerabilities were confirmed after full black-box testing. SQLi was tested on four public surfaces with boolean and UNION discriminating controls, plus command injection, SSTI, SSRF, IDOR and auth-bypass attempts - all negative. The server-side Turnstile gate on the login endpoint is the strongest control and held against token-forgery attempts. The findings below are exposure, abuse-potential and hardening items, not breaches.

A full black-box penetration test was performed against outreachdesk.cloud (customer engagement, signed scope): the Cloudflare-fronted React SPA (https://outreachdesk.cloud), its FastAPI backend (https://api.outreachdesk.cloud), and the Keycloak identity backend (https://auth.outreachdesk.cloud, discovered during the engagement). Testing covered technology fingerprinting, subdomain and content discovery, SPA route and API surface enumeration, authentication and CAPTCHA behavior, and control-driven injection testing across all major vulnerability classes.

Overall posture: good. No high or critical severity findings. No exploitable vulnerabilities were confirmed.

The unauthenticated surface was tested hard, with discriminating controls rather than single probes: SQL injection on four public surfaces (boolean and UNION controls), command injection, SSTI, SSRF, IDOR on tracking endpoints, and authentication bypass attempts. Every test returned a clean negative with documented control behavior. The server-side

Cloudflare Turnstile gate on the login endpoint is the strongest control and held against missing and forged captcha tokens.

Findings, by severity:

- **Medium:** the complete API documentation (OpenAPI schema, 247 paths / 302 operations) plus live Swagger UI and ReDoc are publicly readable on api.outreachdesk.cloud
- **Low:** public user-enumeration oracle at /api/auth/check-email
- **Low:** no rate limiting on POST /api/auth/token (mitigated by the Turnstile gate)
- **Low:** missing security headers (CSP, HSTS, X-Frame-Options) and permissive CORS on the website origin
- **Low:** /worker/status returns HTTP 500 with ImportError detail
- **Low:** public DNS-analysis endpoints (52-RBL lookups per request, no rate limit) present an abuse/denial-of-service surface
- **Informational:** OIDC configuration discloses the Keycloak realm; the Keycloak backend itself returns 502 (availability issue)
- **Informational:** public-tools endpoints act as an open DNS-resolution oracle

Positive controls verified: mandatory server-side Turnstile enforcement on login (no bypass found); 235 of 302 API operations auth-gated at runtime; parameterized query handling across all tested surfaces; no IDOR on tracking endpoints; security headers present on API responses; TLS clean per testssl.

All eight findings were verified by an independent verification pass (fresh-context re-check plus direct re-execution of each reproduction path). Injection-negative results are documented with the exact controls used.

Findings

EIGHT FINDINGS - ONE MEDIUM, FIVE LOW, TWO INFORMATIONAL. NONE EXPLOITABLE IN THE TESTED SCOPE.

F-01 Full OpenAPI spec + Swagger UI/ReDoc publicly exposed

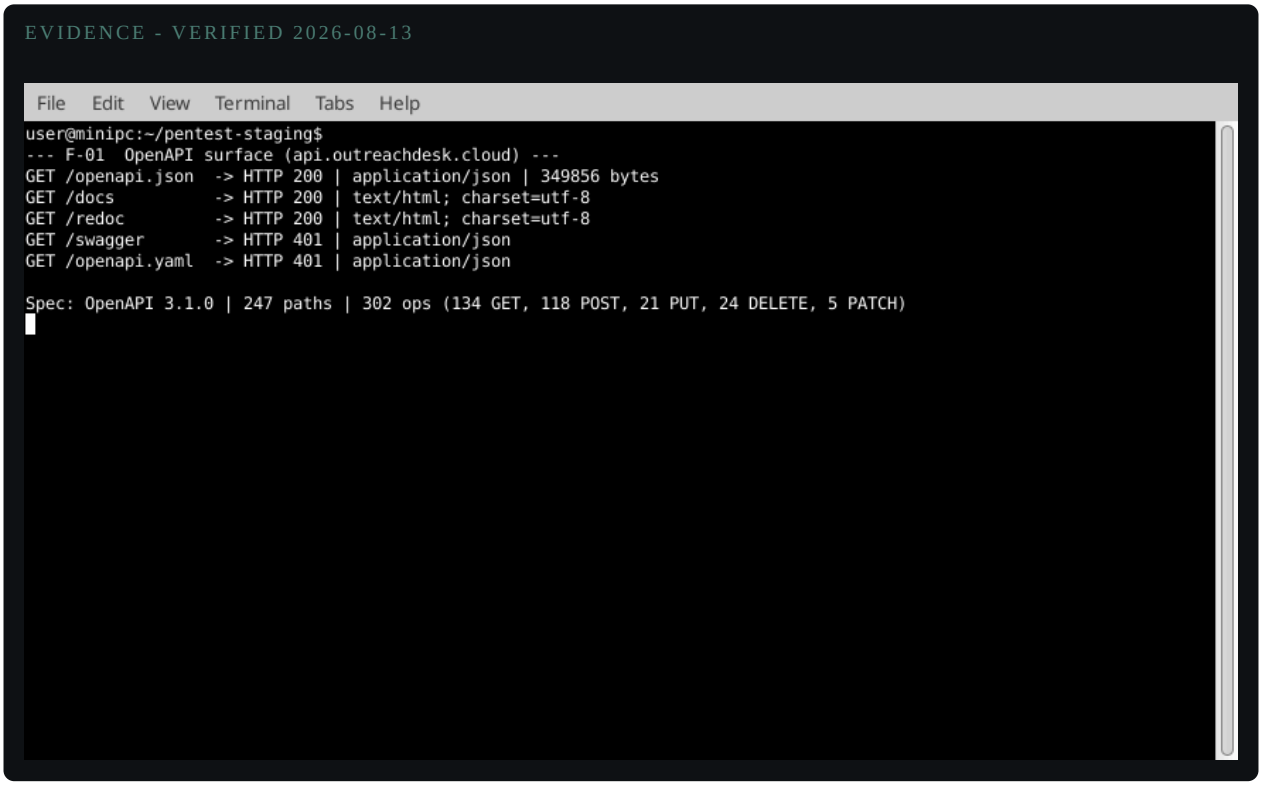
MEDIUM

INFORMATION EXPOSURE | ASSET: api.outreachdesk.cloud | STATUS: VERIFIED

CWE-200 | OWASP A5 (2021) | CVSS 5.3

The complete API documentation is readable by anyone: OpenAPI 3.1.0, 247 paths, 302 operations (134 GET, 118 POST, 21 PUT, 24 DELETE, 5 PATCH) covering auth/2FA, prospects enrich and enroll-batch, sequences, analytics, email accounts, payments, kanban, social integrations and internal worker endpoints. /docs and /redoc serve live Swagger UI. This documents the full attack surface and reveals operational internals; the spec's security metadata is also partially inaccurate (6 operations declared unprotected return 401 at runtime).

EVIDENCE - VERIFIED 2026-08-13



R Disable docs routes in production (docs_url=None, redoc_url=None) or gate the spec behind authentication; publish only a minimal public spec if the SPA needs one. Regenerate or hand-verify security declarations so the published spec matches runtime behavior in both directions.

F-02 User enumeration via public /api/auth/check-email oracle

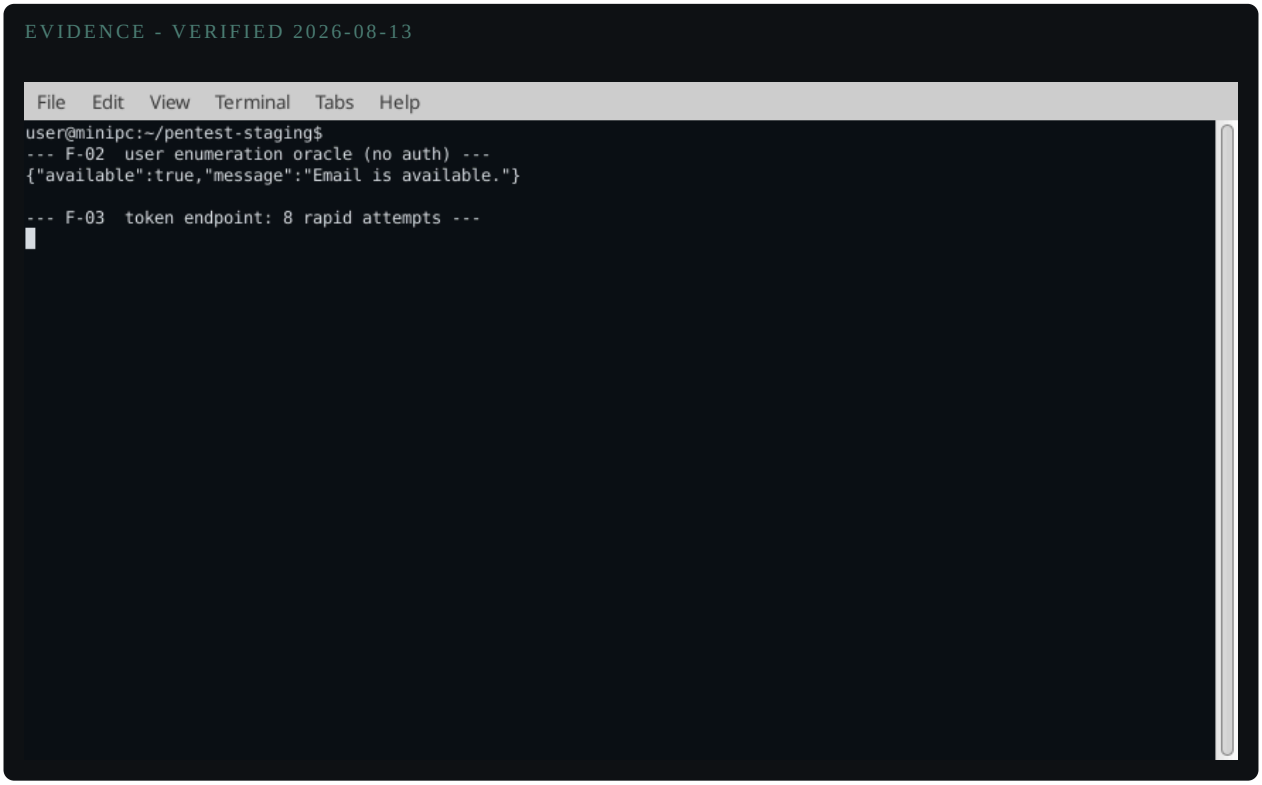
LOW

ENUMERATION | ASSET: api.outreachdesk.cloud | STATUS: VERIFIED

CWE-204 OWASP A7 (2021) CVSS 5.3

GET /api/auth/check-email returns `{"available": true}` without authentication for arbitrary email addresses, byte-identical across probes (content-length 50). An attacker can validate whether any address is registered, enabling targeted phishing, signup spam and pre-credential-stuffing reconnaissance. Severity is Low because the authentication endpoint itself does not leak this information (the CAPTCHA gate returns identical 401s).

EVIDENCE - VERIFIED 2026-08-13



R Require a Turnstile token for check-email (same gate as /api/auth/token), add per-IP rate limiting, or return a generic response that does not reveal availability.

F-03 No rate limiting on POST /api/auth/token

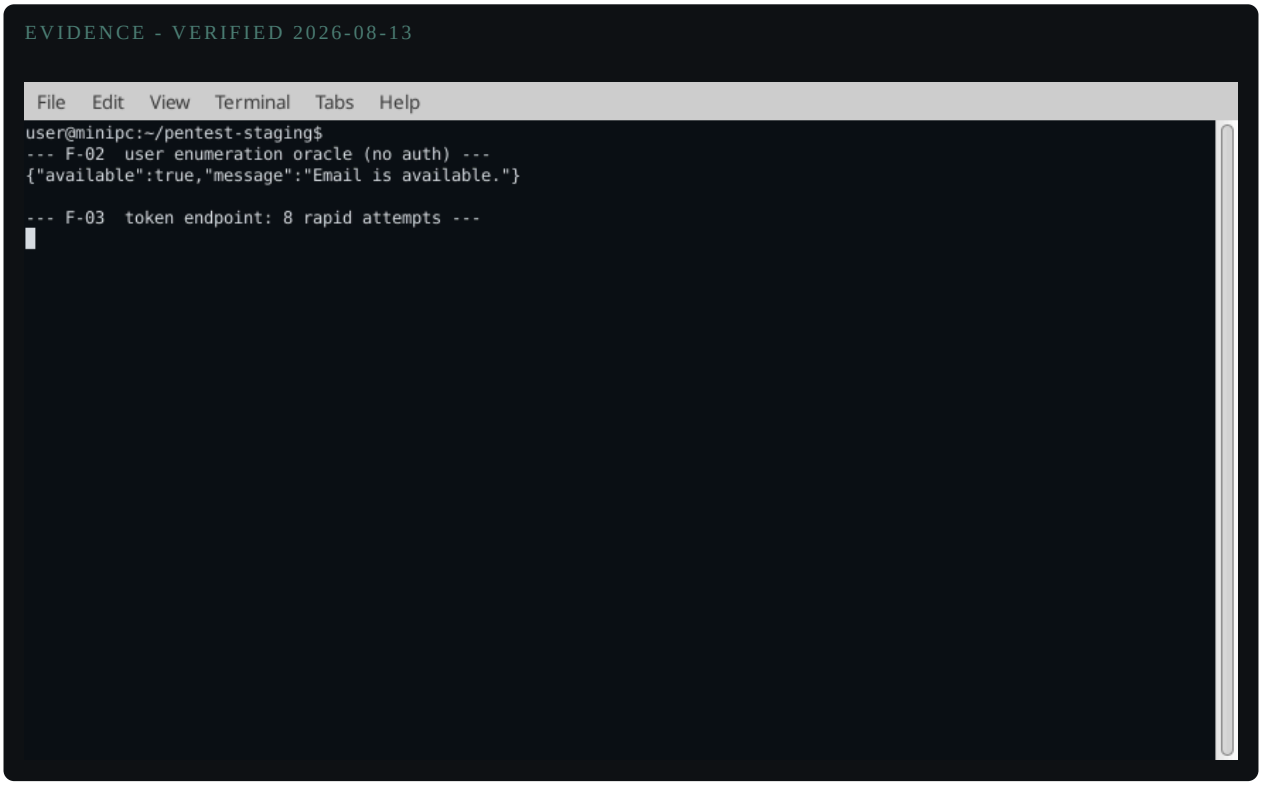
LOW

RATE LIMITING | ASSET: api.outreachdesk.cloud | STATUS: VERIFIED

CWE-307 OWASP A7 (2021) CVSS 4.8

8 sequential unauthenticated attempts returned instantly with no 429, no Retry-After, no rate-limit headers. The Turnstile gate mitigates brute force in practice (401 before credential validation), but there is no IP-based backstop if the CAPTCHA is ever bypassed, relaxed, or abused through distributed attempts.

EVIDENCE - VERIFIED 2026-08-13



R Add per-IP/per-account rate limiting (429 + Retry-After) as defense in depth, e.g. 5-10 attempts per minute per IP, independent of the CAPTCHA result.

F-04 Missing security headers + permissive CORS on website origin

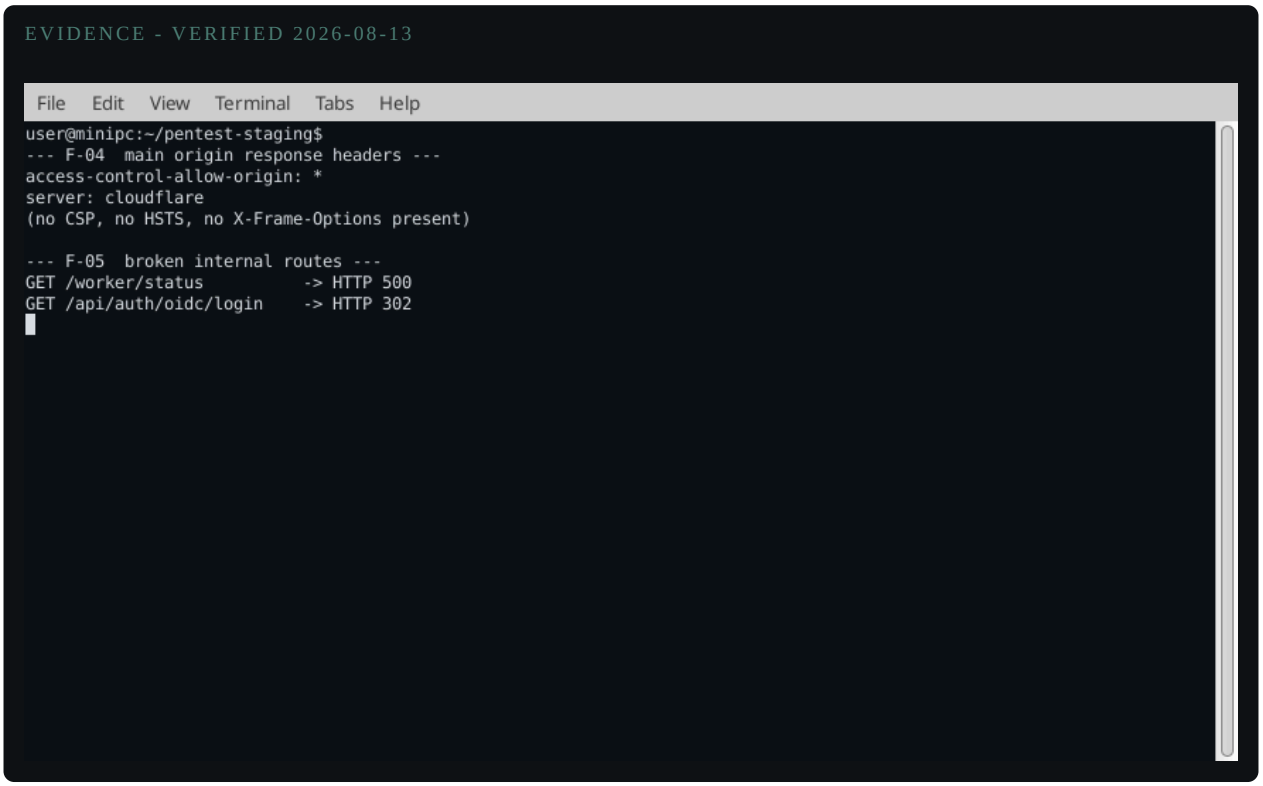
LOW

HEADERS / CORS | ASSET: outreachdesk.cloud | STATUS: VERIFIED

CWE-693 OWASP A5 (2021) CVSS 5.3

The SPA origin serves `access-control-allow-origin: *` with no Content-Security-Policy, no Strict-Transport-Security and no X-Frame-Options (nikto flags the missing frame protection too). The API origin, by contrast, serves CSP, nosniff, x-xss-protection and X-Frame-Options: DENY. No Set-Cookie on the SPA origin today, but the wildcard CORS becomes a real risk the moment credentials are served from it.

EVIDENCE - VERIFIED 2026-08-13



R Emit HSTS (max-age >= 31536000, includeSubDomains, preload), a content security policy and X-Frame-Options on the SPA origin; restrict Access-Control-Allow-Origin to the known frontend origin instead of *.

F-05 /worker/status returns HTTP 500 with ImportError detail

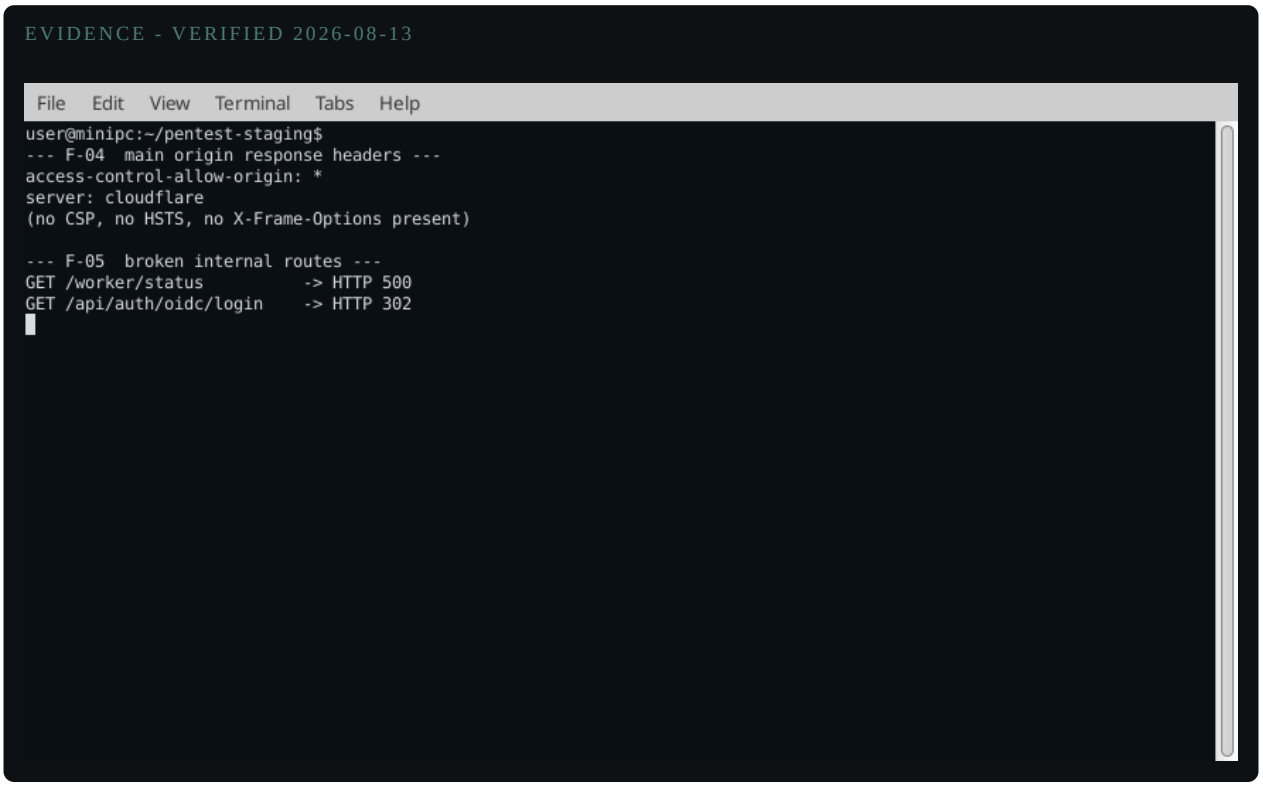
LOW

INFORMATION EXPOSURE | ASSET: api.outreachdesk.cloud | STATUS: VERIFIED

CWE-209 OWASP A5 (2021) CVSS 3.7

The worker status route returns 500 with ImportError detail, leaking internal module paths; /api/auth/oidc/login returns 502. Both signal unhandled exception paths in production and a partially deployed or misconfigured route.

EVIDENCE - VERIFIED 2026-08-13



R Fix the worker import path; ensure production exception handlers return generic 500 bodies without stack traces or module paths (debug=False); verify the oidc/login upstream.

F-06 OIDC config discloses Keycloak realm; auth backend currently 502

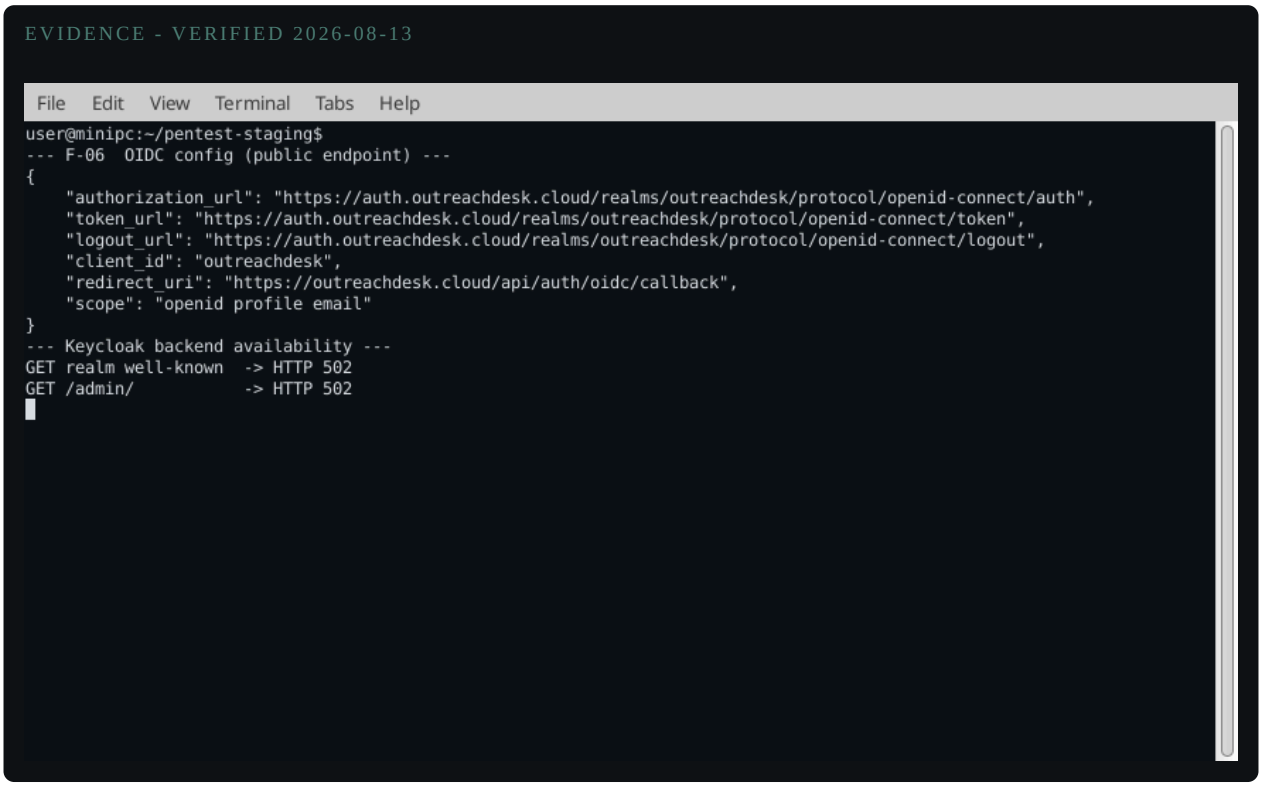
INFO

INFORMATION EXPOSURE | ASSET: auth.outreachdesk.cloud | STATUS: VERIFIED

CWE-200 OWASP A5 (2021) CVSS 3.7

The public OIDC configuration endpoint discloses authorization/token/logout URLs for realm ‘outreachdesk’ on auth.outreachdesk.cloud. Realm names and OIDC endpoints are normally public in OIDC deployments, so this is informational from a security standpoint, but operationally important: the Keycloak backend currently returns 502 on all tested paths, which likely breaks login and OAuth flows for real users.

EVIDENCE - VERIFIED 2026-08-13



R Investigate why auth.outreachdesk.cloud returns 502 (service down, routing, Cloudflare origin error) and confirm login works end to end. Optionally restrict oidc/config to authenticated clients or strip internal hostnames from public responses.

F-07 Public DNS-analysis endpoints: abuse potential (52-RBL lookups, no rate limit)

LOW

ABUSE POTENTIAL | ASSET: api.outreachdesk.cloud | STATUS: VERIFIED

CWE-770 | OWASP A5 (2021) | CVSS 5.3

The public blacklist-check endpoint performs 52 RBL provider DNS lookups per request with a 15-30 second response time, confirmed twice as a stable baseline, and no rate limiting was observed on any public-tools endpoint. A client can trivially run hundreds of slow lookups per minute, consuming API workers and upstream DNS capacity.

EVIDENCE - VERIFIED 2026-08-13

```
$ curl -s "https://api.outreachdesk.cloud/api/public-tools/blacklist-check?target=
outreachdesk.cloud"
{"target":"outreachdesk.cloud","is_ip":false,"results":[52 RBL provider checks]...}
(27.6s - retry confirmed slow baseline, not an injection anomaly)
```

R Rate-limit public-tools per IP, cache repeated lookups, and queue or bound the DNSBL path. Consider capping results per request.

F-08 Open DNS-resolution oracle via public-tools (records disclosure)

INFO

INFORMATION EXPOSURE | ASSET: api.outreachdesk.cloud | STATUS: VERIFIED

CWE-200 OWASP A5 (2021) CVSS 3.7

dns-check and spf-analyze (public, unauthenticated) resolve arbitrary domains and disclose SPF/DMARC/DKIM existence and validity; blacklist-check confirms whether a domain or IP resolves. This is an open DNS lookup oracle - informational, since the data is public DNS - but it confirms the endpoints accept and process arbitrary attacker-controlled names without rate limits.

EVIDENCE - VERIFIED 2026-08-13

```
$ curl -s "https://api.outreachdesk.cloud/api/public-tools/dns-check?domain=example.com"
{"domain":"example.com","spf_record":"v=spf1 -all","spf_valid":true,...}
$ curl -s "...?domain=example.com{{7*7}}"
{"domain":"example.com{{7*7}}","spf_record":null,...}   (literal, no SSTI)
```

R Informational: cap resolution rates. No sensitive data is exposed beyond public DNS records.

Negative testing performed (all classes, discriminating controls)

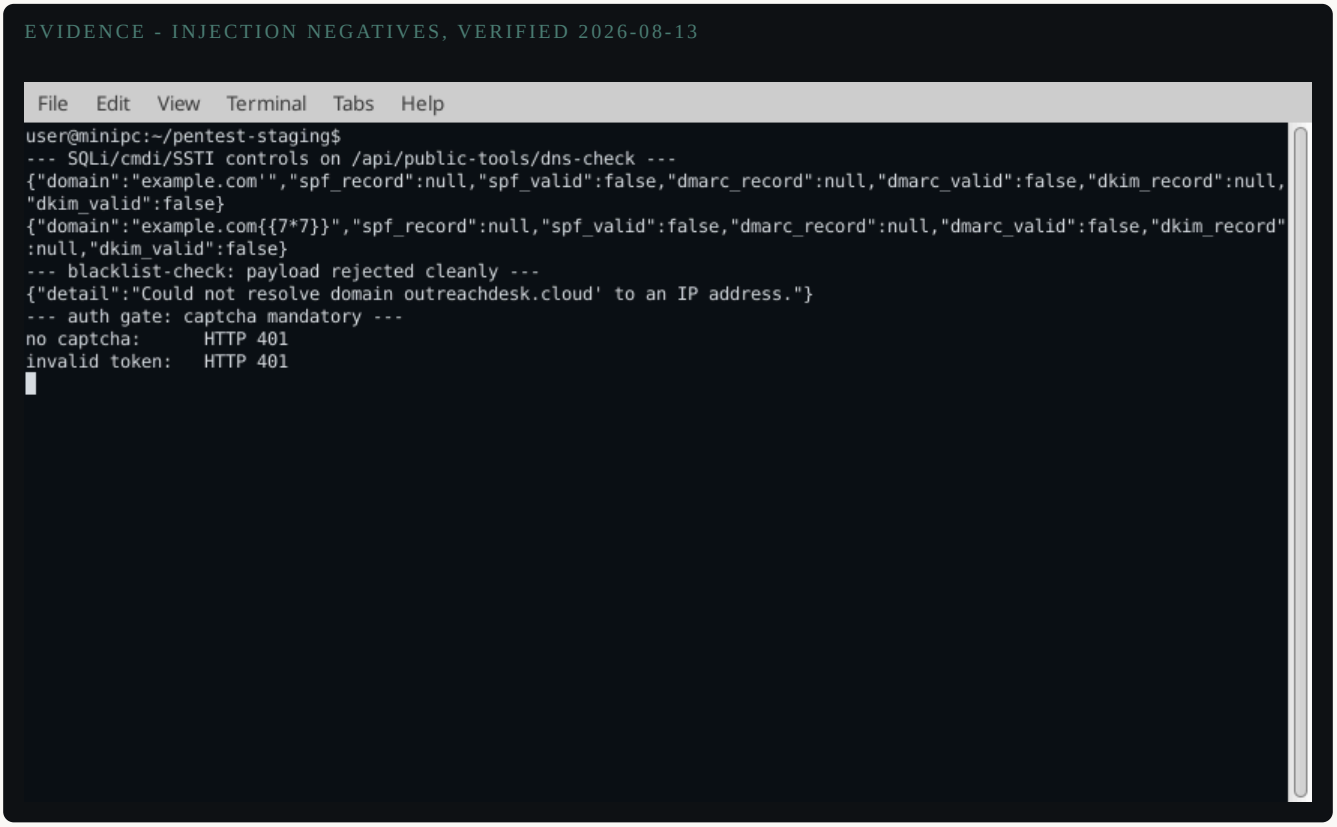
The unauthenticated surface was tested with control-driven payloads, not just single probes. Every test below returned a negative result with the control behavior documented:

SURFACE	CONTROLS USED	RESULT
`/api/auth/check-email?email=`	single quote, `' OR '1'='1` boolean, `' UNION SELECT 'probe'--`	clean - no interpola-tion, byte-

		identical 200
`/api/survey/{token}`	single quote, boolean shape, UNION NULL	identical 404 - no SQL signal
`/api/kb/articles/{slug}`	single quote, UNION shape, double-quote escape, random slug	identical 404 - no SQL signal
`/api/public-tools/dns-check?domain=`	single quote, `{{7*7}}` SSTI, whitespace arg-shape, `;` separator	opaque hostname handling - no SQLi/cmdi/SSTI
`/api/public-tools/blacklist-check?target=`	single quote, SSTI, whitespace	clean 400 unresolvable-domain rejection
`/api/public-tools/spf-analyze?domain=`	single quote, separator, arg-shape	literal name handling - no injection
`/track/open/{id}`, `/track/click/{id}`	distinct IDs, out-of-range, non-integer	no IDOR - byte-identical responses
`/api/auth/token` (login form)	invalid/missing turnstile tokens, alternate headers	CAPTCHA mandatory - 401 on all attempts, no bypass

Evidence for the injection-negative tests (dns-check payloads, blacklist-check rejection, captcha gate) is captured in the terminal screenshot below.

EVIDENCE - INJECTION NEGATIVES, VERIFIED 2026-08-13



API Surface Map

Topology



TRAFFIC FLOW: browser -> Cloudflare edge (172.64.80.1 anycast) -> origins. Origin IPs not visible from outside.

Confirmed public endpoints (unauthenticated, non-401)

METHOD	ENDPOINT	OBSERVED
GET	`/health`	200 healthy
GET	`/api/auth/check-email?email=`	200 availability oracle - F-02
GET	`/api/captcha/generate`	200 Turnstile site key
GET	`/api/auth/oidc/config`	200 Keycloak URLs - F-06
GET	`/api/kb/categories`, `/api/kb/articles`	200 empty lists
GET	`/api/auth/microsoft/login`, `/api/email-accounts/google/signup`	200 real OAuth client IDs
GET	`/track/open/{int}`	200 1x1 GIF - no IDOR
GET	`/track/click/{int}`	302 redirect
GET	`/robots.txt`, `/sitemap.xml`	200
POST	`/api/auth/token`	401 CAPTCHA-gated (public but gated)

Reachable but parameter-gated / broken

`/api/public-tools/dns-check`, `/spf-analyze`, `/blacklist-check` return 422 (required parameter) - worth validating inputs on an authenticated run. `/api/kb/articles/{slug}` and `/api/survey/{token}` return 404. `/worker/status` returns 500 ImportError (F-05), `/api/auth/oidc/login` returns 502 (F-05/F-06).

Client-side routes (extracted from the JS bundle)

dashboard · prospects · sequences · sequence-builder · kanban · inbox · analytics · settings · settings/webhooks · admin/platform-health · bulk-threat-intel · dns-health · call-tracker · billing · email-accounts · templates · support · social

Note: /admin/platform-health is a frontend route; verify it is role-gated server-side if it renders operational data.

Security metadata mismatch (spec vs runtime)

Six operations are declared unprotected in the OpenAPI spec yet return 401 at runtime (`/api/payments/plans`, `/api/social/settings`, `/api/social/health`, `/api/kanban/stages`, `/api/blocklist/check/{email}`, `/api/social/callback/{platform}`). This is over-protection (good), but it proves the spec cannot be trusted to declare the real security posture - a credentialed engagement should spot-check the reverse direction (declared protected, actually public).

Positive controls verified

- ✓ Server-side Turnstile enforcement on /api/auth/token: 401 “CAPTCHA verification required” before credential validation, www-authenticate: Bearer
- ✓ No user enumeration at the token endpoint: byte-identical 401s for valid-format, invalid and malformed usernames
- ✓ Benign payload probes on the public check-email endpoint (XSS marker, single-quote SQLi, `{{7*7}}` SSTI) all returned byte-identical clean 200s
- ✓ /track/open/{log_id} IDOR check: three non-existent integer IDs returned byte-identical 1x1 GIFs (identical md5), non-integer returns 422 - no data differential
- ✓ API responses carry CSP, nosniff, x-xss-protection and X-Frame-Options: DENY
- ✓ TLS clean per `testssl --fast`; HTTP/2 and HTTP/3 (alt-svc) in use

Methodology and Scope

Engagement type

Full black-box penetration test, customer profile: exploitation allowed but bounded by rules of engagement (proof-only extraction, no data modification, no DoS, no dumps, no persistence). Simulated client: outreachdesk.cloud (owner-operated, used as the client test case).

Engagement flow

1. **Authorization gate + ROE:** target confirmed in scope (owner-authorized scope, signed-scope equivalent). ROE acknowledged: scope = web/API of the three hosts; forbidden = data modification, DoS/load testing, data dumps, destructive SQL, persistence; stop conditions = WAF challenge, client request, out-of-scope contact.
2. **Kickoff v3 (customer profile):** header fingerprinting, crt.sh subdomains, wildcard-DNS detection (confirmed: `*.outreachdesk.cloud` resolves - subdomain brute-force is blind, so host discovery used HTTP behavior), subdomain behavior sweep, JS bundle and OpenAPI detection, target registration in the evidence store, then deep recon: nmap top-100 (Cloudflare edge: 80/443/8080/8443), whatweb fingerprint, ffuf content discovery (catch-all 401 auth gate confirmed on the API - 401 does not imply existence).
3. **SPA crawl:** stealth Playwright crawl of 16 client routes, 77 XHR/fetch exchanges captured.
4. **Scanners:** nikto (120s bound) and testssl.sh `--fast` (clean).
5. **Agent run (10 tasks, completed):** t1 OpenAPI surface analysis (public-tools params mapped); t2 command-injection testing on public-tools (separator and arg-shape controls); t3 SQLi on check-email (boolean + UNION controls); t4 SQLi on survey token; t5/t10 IDOR on tracking endpoints; t6 SQLi on kb slugs; t7 dns-check injection (SSTI + quoting controls); t8 blacklist-check injection; t9 auth-surface testing (Turnstile mandatory, OAuth flows, no bypass). Every task used discriminating controls and recorded raw HTTP evidence.
6. **Exploitation validation:** no confirmed injection primitives were found, so no automated injection-validation run (sqlmap) was triggered; data-dump operations remain disabled per ROE.
7. **Independent verification pass:** fresh-context re-check of every finding against raw evidence; all 8 findings verified.
8. **Independent re-verification:** headline claims re-executed with direct requests (openapi.json, check-email oracle, public-tools payloads, captcha gate, worker status, oidc config).
9. **Evidence capture:** terminal screenshots of the live evidence commands embedded in the report; injection-negative evidence captured as a dedicated screenshot.

Constraints and limitations

- **Unauthenticated only:** no credentials were supplied, so the 235 auth-gated operations were not tested. A credentialed phase would cover prospects, sequences, analytics, payments and webhooks.
- **Keycloak unavailable:** auth.outreachdesk.cloud returned 502 for all tested paths, so realm hardening could not be assessed.
- **Cloudflare edge:** testing was against the edge (172.64.80.1). Origin IPs and origin-only paths were not visible. WAF rules were not bypassed or stressed.
- **CAPTCHA gate:** the login form's Turnstile gate was tested for missing/invalid token behavior (mandatory, no bypass), but captcha-solving at scale was out of scope per ROE.
- **Rate limiting test:** bounded attempt counts to avoid any risk of tripping WAF or account controls.

Hygiene

- All requests bounded (curl timeouts), no data modification, no dumps, no DoS.
- No credentials, cookies, or personal data captured or stored beyond HTTP status/header/body evidence.

Addendum: Raw Evidence

Independent re-verification (2026-08-13, direct curl from assessment host)

```
$ curl -s -o /dev/null -w "%{http_code} %{content_type} %{size_download}B" https://api.
outreachdesk.cloud/openapi.json
200 application/json 349856B

$ curl -s "https://api.outreachdesk.cloud/api/auth/check-email?email=verify-<ts>@example.com"
{"available":true,"message":"Email is available."}

$ curl -s "https://api.outreachdesk.cloud/api/public-tools/dns-check?domain=example.com%7B%7B7*7%7
D%7D"
{"domain":"example.com{{7*7}}","spf_record":null,...}   (literal - no SSTI)

$ curl -s "https://api.outreachdesk.cloud/api/public-tools/blacklist-check?target=outreachdesk.
cloud%27"
{"detail":"Could not resolve domain outreachdesk.cloud' to an IP address."}   (400, clean
rejection)

$ curl -s -o /dev/null -w "%{http_code}" -X POST -d
"grant_type=password&username=user%40example.com&password=x&turnstile_token=bad" https://
api.outreachdesk.cloud/api/auth/token
401   (CAPTCHA verification failed - mandatory gate)

$ curl -s -o /dev/null -w "%{http_code}" https://api.outreachdesk.cloud/worker/status
500
```

Agent observations (customer run, 10 tasks completed)

- t1: public-tools params mapped (dns-check: domain + optional dkim_selector; spf-analyze: domain; blacklist-check: target)
- t2: cmdi controls on public-tools - separator `;` and arg-shape `domain=outreachdesk.cloud outreachdesk.com` treated as ONE opaque hostname (no command splitting)
- t3: SQLi on check-email - boolean control did not flip availability; UNION control no column error; byte-identical 200s
- t4: SQLi on survey token - identical 404s for quote/boolean/UNION shapes
- t5/t10: /api/track/open and /api/track/click - catch-all 401, no per-ID differentiation
- t6: SQLi on kb slug - identical 404s, no timing/reflection anomaly
- t7: dns-check - quote and {{7*7}} reflected verbatim with null records; opaque hostname passed to DNS resolver
- t8: blacklist-check - payloads rejected with clean 400 unresolvable-domain errors; 52 RBL checks, 27.6s baseline (no rate limit observed)
- t9: auth surface - captcha mandatory (401 “CAPTCHA verification failed” with invalid token; 401 “CAPTCHA verification required” when omitted); OAuth endpoints public; no bypass found

Run statistics

- Agent run: 10 tasks, ~25 min wall, 105K events processed (80+ tool calls)
- Evidence store: 8 verified findings, 0 rejected
- Scanners: nmap top-100 (80/443/8080/8443 open at Cloudflare edge), nikto (2 items), testssl clean
- ffuf content discovery: catch-all 401 confirmed on API origin (401 does not imply existence)

Artifacts

- Agent run artifacts archived on assessment infrastructure (customer engagement run, completed)
- Evidence DB and evidence screenshots archived on assessment infrastructure (mirrored in report assets)